POPIA Compliance for Schools in South Africa

Why It Matters

Since July 1, 2021, all South African schools must comply with POPIA. Non-compliance carries penalties up to R10 million or 10 years' imprisonment. Every school is a "Responsible Party" under the Act — ignorance is not an excuse.

The Key Challenges

1. Handling children's data — and getting consent right

This is the most high-profile area of failure. The Department of Basic Education published the 2023 matric results without securing consent from students over 18, or from parents/guardians of those under 18. The Information Regulator ruled this non-compliant with POPIA and ordered the DBE to cease newspaper publication and adopt privacy-compliant alternatives like secure SMS platforms.

For schools, this plays out daily — photos on websites, newsletters, social media posts, and WhatsApp class groups all routinely expose learner data without proper consent.

2. Photos and social media

Taking photos of learners for Facebook, newsletters, or the school website requires explicit consent. Parents should be able to opt out of any category without it affecting enrolment. Most schools have no formal process for this, making it one of the most common areas of inadvertent non-compliance.

3. Confusing compliance with just having a security policy

Some organisations are under the mistaken impression that a security policy or access management policy constitutes a compliance framework. This is not so. The POPIA compliance framework must specify exactly what steps are being taken to comply with POPIA, in particular each of the conditions of lawful processing.

4. Overlooking the human/organisational side

Organisations often emphasise the technical measures they have in place to prevent data breaches but overlook the organisational measures. The Information Regulator has stressed that organisations also need to pay attention to the operational measures taken — and particularly the conduct of their employees. Staff sharing learner information over unsecured WhatsApp groups is a classic school-specific example.

5. Third-party vendors and school management software

Schools must review their POPIA policy with software vendors, sign data processing agreements, verify security measures (encryption, access controls, backup procedures), check where data is

stored, and confirm breach notification obligations. Many schools use unvetted apps for attendance, communication, and administration without any of these controls in place.

6. Low digital literacy and resource constraints

The South African context must be situated within broader challenges facing developing countries — namely, limited enforcement capacity, low digital literacy, and infrastructural constraints. Smaller public schools in particular struggle to resource compliance meaningfully.

7. The 2025 regulatory tightening

In April 2025, the Information Regulator published amendments to POPIA Regulations, introducing new responsibilities for information officers and simplifying processes for objecting to data processing, requesting corrections or deletions, and obtaining consent. Schools that set and forgot their 2021 compliance work need to revisit it.

What Schools Should Do

Appoint and register an Information Officer.

The principal typically serves as the Information Officer and must be registered with the Information Regulator. This is a legal requirement, not optional. The IO can then designate **Deputy Information Officers (DIOs)** to assist with day-to-day compliance functions. The IO remains legally accountable regardless. The most practical approach for most schools — particularly independent and well-resourced government schools — is a **hybrid**:

- **Outsource the DIO function** to a reputable specialist for the technical compliance work: framework development, impact assessments, vendor due diligence, breach response, and IR liaison.
- **Appoint an internal "POPIA champion"** — an administrator or bursar — as a point of contact who liaises with the outsourced DIO and keeps day-to-day practices aligned.
- **Ensure the principal (IO) is genuinely briefed** at least quarterly, not just named on a form.

This gives schools genuine expertise without expecting educators to become privacy lawyers, while keeping enough internal ownership that compliance is lived rather than just papered over.

Conduct a data audit

Map exactly what personal information the school collects — learner names, ID numbers, addresses, medical conditions, academic records, photographs, and parent and staff details all fall under POPIA. Medical data and biometrics are "special personal information" requiring extra protection.

Fix enrolment forms

Include POPIA notices, purpose statements, and explicit photo/biometrics consent with opt-out options. Parents should be able to decline social media or marketing use without it affecting their child's enrolment.

Secure physical and digital records

Paper records must be locked in secure filing cabinets. Digital records must be password-protected with access restricted to authorised staff only.

Train all staff

The number one cause of reported POPIA incidents is human error. Every staff member handling learner or parent data needs to understand what they can and cannot do.

Have a breach response plan

Under the 2025 regulations, all security compromises must be reported to the Information Regulator as soon as you are reasonably sure — not after a full investigation.

Build a proper compliance framework

Not just a policy document. The IR's own initiative assessments look for personal information impact assessments and compliance frameworks that demonstrate specifically how the organisation addresses risks and the steps it has taken.

The Bottom Line

Schools sit in a uniquely exposed position — they hold sensitive data on minors, involve dozens of staff, and interact with hundreds of parents across multiple digital channels. The DBE matric results case is a clear warning that the Information Regulator is willing to act against educational institutions. The good news is that the basics — proper consent, sensible access controls, staff awareness, and a formal compliance framework — are achievable without enormous cost. The risk of doing nothing, however, keeps growing.